
PLAN DE REPRISE D'ACTIVITÉ (PRA) : AEROTECH

Entreprise : AeroTech Version : 5.0 (Version Intégrale - Stratégique & Technique)

Auteurs : Aurélien VERQUIN, Axel DUBOIS, Pierre DEBAY, Benjamin LEPRETRE

Diffusion : Interne / Confidentiel (Soumis à la norme EN9100)

NOTE DE SYNTHÈSE (Executive Summary)

Destinataire : Comité de Direction AeroTech

PLAN DE REPRISE D'ACTIVITÉ (PRA) : AEROTECH	1
1. LE CONSTAT	3
2. LA STRATÉGIE	3
3. LES ENGAGEMENTS (SLA)	3
4. GOUVERNANCE & RESPONSABILITÉ	4
1. PRÉSENTATION DU CONTEXTE ET ENJEUX	5
1.1. Présentation Générale d'AeroTech	5
1.2. Architecture du Système d'Information	5
1.2.1 Vue Globale d'Architecture (Schéma de Référence)	6
1.2.2 Description de l'Architecture Hybride (Légende du Schéma)	7
1.2.3 Hiérarchie de Criticité Métier (Schéma BIA)	8
1.2.4 Détail des 5 Niveaux de Criticité	9
● Niveau 1 - ABSOLUE : Production ERP + Sauvegarde Locale	9
● Niveau 2 - STRATÉGIQUE : Réplication Hors Site + Stockage WORM	9
● Niveau 3 - HAUTE : Cluster Pare-feu Redondant	10
● Niveau 4 - MOYENNE : VPN IPsec AES-256 + Serveurs CAO/PLM	11
● Niveau 5 - SUPPORT : Internet Redondance (Fibre + 4G/Starlink)	12
Synthèse - Matrice de Restauration Prioritaire	13
1.3. Enjeux et Contraintes Critiques	14
2. ANALYSE D'IMPACT SUR L'ACTIVITÉ (BIA) ET OBJECTIFS (SLA)	15
2.1. Échelle de Gravité et Contexte	15
2.2. Hiérarchie de Criticité Métier (SLA)	16
3. ANALYSE DE RISQUES (MÉTHODE EBIOS RM)	17
4. ARCHITECTURE TECHNIQUE & SÉCURITÉ	19
4.1. Vue Logique Détaillée (Architecture Hybride)	19
4.2. Gestion des SPOF (Single Point of Failure)	21
4.3. Souveraineté	21
5. STRATÉGIE DE REPRISE ET GESTION DE CRISE	22
5.1. Stratégie de Sauvegarde Technique (3-2-1-1-0)	22
5.2. Procédure de Gestion de Crise (Phase Initiale)	22
5.3. RUNBOOK TECHNIQUE (Ordre strict de Reprise)	23
5.4. Annuaire de Crise (Matrice RACI)	23
5.5. Tests et MCO (Maintien en Condition Opérationnelle)	24
6. CONFORMITÉ RGPD & CADRE LÉGAL	25
6.1. Gouvernance et Mesures Techniques	25
6.2. Cartographie des Données (Registre des Traitements)	25
6.3. Sous-traitance et Souveraineté	25

1. LE CONSTAT

En tant que sous-traitant de rang 1 pour Airbus, AeroTech ne peut se permettre un arrêt de production prolongé. Notre dépendance au numérique (ERP, CAO) est totale. Le point de rupture est identifié à 4 heures. Au-delà, les camions sont bloqués, les livraisons cessent, et nous risquons des pénalités ou une rupture de contrat.

2. LA STRATÉGIE

Nous avons adopté une architecture de défense en profondeur pour garantir la survie de l'entreprise face aux deux risques majeurs : le Ransomware et l'Incendie.

- Règle du 3-2-1-1-0 pour les sauvegardes : Nos données sont répliquées sur un site distant (>50km) dans un "Coffre-fort numérique" immuable. Même si un pirate chiffre toute l'usine, il ne peut pas détruire cette sauvegarde distante.
- Segmentation (Cloisonnement) : L'usine (Automates) est isolée d'Internet. Le Cloud (Plans CAO) est accessible uniquement via un tunnel sécurisé (VPN). Une infection sur un PC de bureau ne peut plus se propager librement vers la production.

3. LES ENGAGEMENTS (SLA)

- ERP Production : RTO 4 Heures / RPO 1 Heure (Vital pour éviter le blocage logistique).
- Bureau d'études : RTO 24 Heures (J+1) / RPO 24 Heures (Acceptable, chômage technique temporaire).

4. GOUVERNANCE & RESPONSABILITÉ

- Gestion de Crise : Une procédure stricte et une checklist opérationnelle ont été distribuées. La Direction Générale pilote la crise, la DSI exécute la technique.
- Juridique / RGPD : Nous sommes conformes aux obligations de notification (CNIL, Clients, Assureur). Les données restent souveraines (France/UE).
- Maintien en condition : Ce plan n'est valide que s'il est testé. Un "Crash Test" annuel (bascule réelle) est désormais obligatoire pour valider notre capacité à tenir les 4 heures.

Conclusion : Le risque zéro n'existe pas, mais avec ce PRA, AeroTech passe d'une posture de vulnérabilité à une posture de résilience. Nous transformons une catastrophe potentielle en un incident géré.

1. PRÉSENTATION DU CONTEXTE ET ENJEUX

1.1. Présentation Générale d'AeroTech

AeroTech est une PME industrielle de 400 collaborateurs opérant en tant que sous-traitant stratégique dans le secteur aéronautique. En tant que partenaire de grands donneurs d'ordre comme Airbus, l'entreprise est soumise à des exigences strictes de qualité et de fiabilité. Notre activité repose sur une chaîne de valeur critique allant de la conception (Bureau d'Études) à la fabrication (Usine), nécessitant une disponibilité constante de nos moyens de production et de nos données techniques.

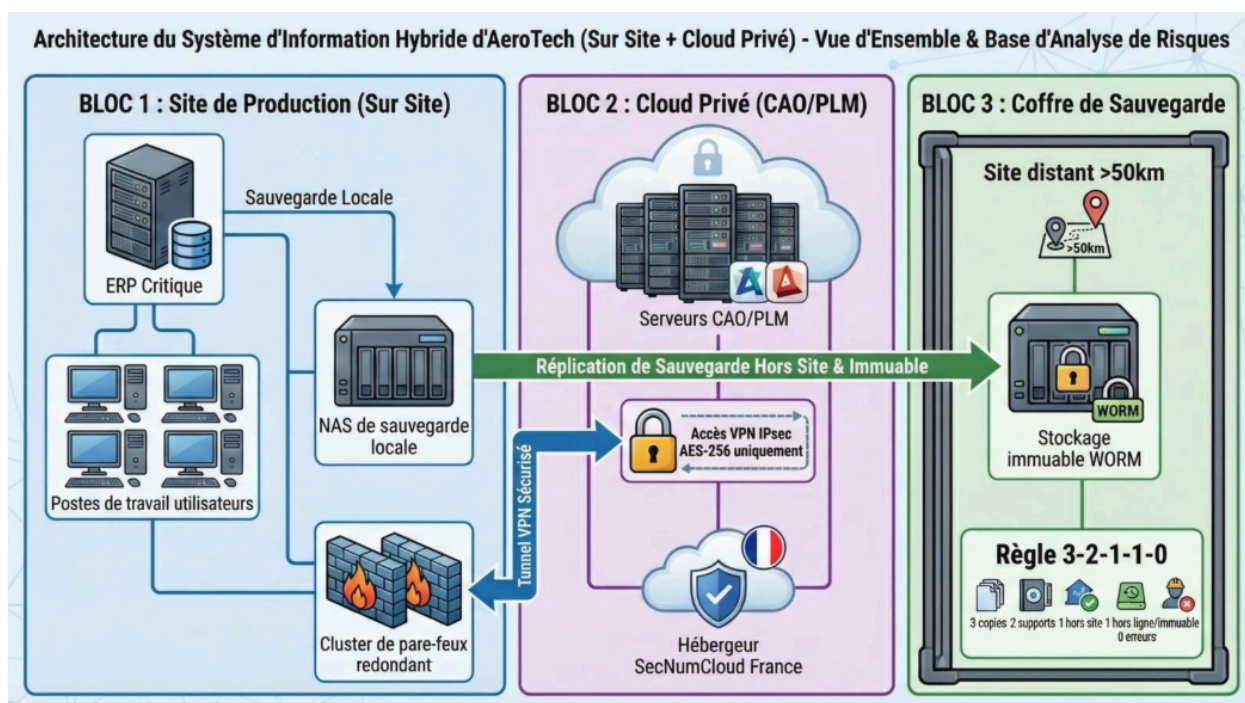
1.2. Architecture du Système d'Information

Le Système d'Information (SI) d'AeroTech est construit sur une architecture **hybride** conçue pour répondre aux besoins spécifiques de nos métiers :

- **Production (On-Premise)** : Notre ERP, cœur de l'activité industrielle (gestion des stocks, ordres de fabrication), est hébergé localement au sein de l'usine pour garantir une latence minimale et une autonomie vis-à-vis d'Internet.
- **Conception (Cloud Privé)** : Les solutions de CAO/PLM, hébergeant nos plans et la propriété intellectuelle, sont externalisées dans un Cloud Privé sécurisé, accessible via une liaison VPN chiffrée.

1.2.1 Vue Globale d'Architecture (Schéma de Référence)

Le schéma ci-dessous présente la vue globale du Système d'Information d'AeroTech, structuré en trois blocs fonctionnels distincts. Cette architecture hybride (On-Premise + Cloud Privé) constitue la fondation de notre analyse de risques, du BIA et de la stratégie de reprise d'activité



1.2.2 Description de l'Architecture Hybride (Légende du Schéma)

Le schéma repose sur 7 éléments clés, organisés en 3 blocs fonctionnels. Chacun joue un rôle critique dans la résilience du PRA

Flux / Élément	Élément Visuel	Description	Justification PCA (Résilience)
 Flux de Sauvegarde Locale		Transfert de données depuis l'ERP critique et les postes de travail vers le NAS local.	Objectif de Point de Récupération Bas (1 heure) : Permet une restauration immédiate sans utiliser le WAN en cas d'erreur humaine.
 Réplication Hors Site		Copie asynchrone des sauvegardes vers le « Coffre-fort » distant situé à plus de 50 km.	Survie en Cas de Catastrophe Majeure : Garantit la disponibilité des données même si l'usine est physiquement détruite (Feu/Inondation).
 Tunnel VPN Sécurisé		Connexion chiffrée AES-256 entre le cluster de pare-feu et le Cloud Privé.	Confidentialité & Continuité : Sécurise la propriété intellectuelle (CAO) tout en permettant un accès transparent aux serveurs distants.
 Cluster de Pare-feu		Paire de pare-feu redondants en mode Actif/Passif.	Haute Disponibilité : Empêche une panne matérielle unique de perturber l'accès à la production ou au Cloud CAO.
 Stockage WORM		Technologie 'Écriture Unique, Lecture Multiple' empêche toute modification.	Anti-Ransomware : Garantit que les sauvegardes ne peuvent pas être chiffrées par des logiciels malveillants.
 Fournisseur d'Hébergement SecNumCloud		Infrastructure souveraine certifiée par l'ANSSI et située en France.	Conformité & Souveraineté : Répond aux exigences strictes d'Airbus et au RGPD pour la protection des données sensibles.

Ces 7 éléments appliquent les principes de défense en profondeur :

- Contre les ransomwares : Snapshots horaires locaux (BLOC 1) + Sauvegarde immuable WORM hors site (BLOC 3)
- Contre les sinistres physiques : Distance géographique >50km entre BLOC 1 et BLOC 3, redondance pare-feux (Actif/Passif)
- Contre l'espionnage industriel : VPN chiffré IPsec AES-256 + MFA + hébergeur SecNum Cloud souverain
- Contre les coupures réseau : Redondance Internet (Fibre + 4G/5G + SD-WAN automatique)
- Contre la perte de données accidentelle : Versionning local (snapshots horaires) + restauration rapide intra-jour

Chacun protège contre un risque spécifique et garantit que AeroTech peut se rétablir rapidement en cas de crise.

L'analyse détaillée des risques pesant sur ces composants est présentée au Chapitre 2 (Analyse de risque). Les objectifs de continuité (RTO/RPO) et les mesures techniques de chacun

1.2.3 Hiérarchie de Criticité Métier (Schéma BIA)

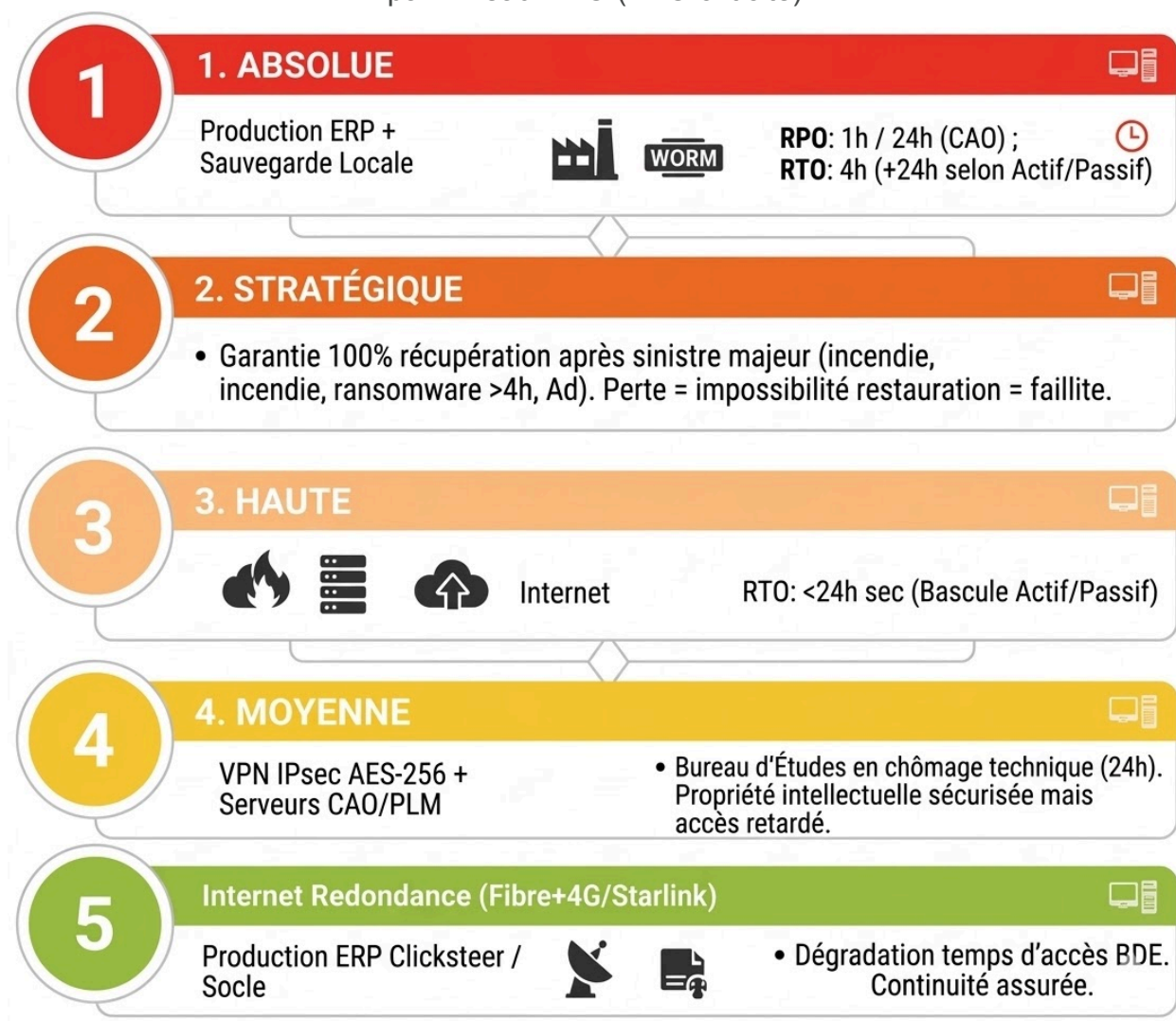
Visualisation des Impacts Métiers et Objectifs de Reprise

Le schéma suivant présente la **hiérarchie de criticité des éléments d'AeroTech**, organisée en **5 niveaux de priorité** selon l'impact métier et les objectifs de continuité (RTO/RPO). Cette classification guide directement les priorités de restauration en cas de sinistre majeur.

Hiérarchie de Criticité Métier (Schéma BIA)

Visualisation des impacts métier et des objectifs de reprise

par Niveau/RPO (RTO criticité)



1.2.4 Détail des 5 Niveaux de Criticité

● Niveau 1 - ABSOLUE : Production ERP + Sauvegarde Locale

Éléments couverts : Production ERP + Flux de Sauvegarde Locale (NAS local)

Objectifs de continuité :

- **RPO** : 1h (perte de données max = 1h d'ordres de production)
- **RTO** : 4h (délai max avant reprise = 4h)
- **Justification mécanisme** : Snapshots horaires + restauration rapide depuis NAS local

Impact métier en cas de défaillance :

- ⚠ **Usine paralysée** en 4h maximum
- ⚠ **Pénalités clients** (retards de livraison, clauses SLA)
- ⚠ **Chômage technique** (salariés sans ordres de fabrication)
- ⚠ **Perte de traçabilité EN9100** (non-conformité qualité)

Pourquoi PRIORITÉ ABSOLUE : L'ERP est le cœur opérationnel de l'usine. Tout arrêt au-delà de 4h crée un préjudice irréversible (pertes financières, dommages réputationnels, défaut de conformité).

● Niveau 2 - STRATÉGIQUE : Réplication Hors Site + Stockage WORM

Éléments couverts : Coffre-fort de Sauvegarde (>50km) + Stockage immuable WORM

Objectifs de continuité :

- **RPO** : 4h (ERP) / 24h (CAO) — perte données max selon type
- **RTO** : 4–24h (selon urgence du sinistre majeur)
- **Justification mécanisme** : Sauvegarde asynchrone + immuabilité anti-ransomware

Impact métier en cas de défaillance :

- ⚠ **Perte totale de récupération** après sinistre majeur
- ⚠ **Impossibilité restauration** = faillite de l'entreprise
- ⚠ **Perte de propriété intellectuelle** (modèles CAO, nomenclatures, brevets)
- ⚠ **Non-conformité légale** (RGPD, souveraineté données)
- **Pourquoi PRIORITÉ STRATÉGIQUE** : Cette couche garantit la survie post-sinistre. Sans sauvegarde hors site protégée contre ransomware, AeroTech ne peut pas se rétablir d'une catastrophe majeure (incendie, ransomware >4h, séisme, inondation). C'est l'**assurance-vie du PRA**.

● Niveau 3 - HAUTE : Cluster Pare-feu Redondant

Éléments couverts : Paire de pare-feux NGFW en mode Actif/Passif + bascule automatique

Objectifs de continuité :

- **RTO** : <30 sec (bascule automatique)
- *Note : RPO non applicable — le pare-feu ne stocke pas de données métier.*
- **Justification mécanisme** : Redondance Actif/Passif + failover automatique

Impact métier en cas de défaillance :

- ⚠ **Exposition Internet** (tout le trafic sort sans filtrage)
- ⚠ **Risque ransomware** (porte ouverte aux attaques externes)
- ⚠ **Arrêt accès Cloud CAO** (BDE isolée du VPN)
- ⚠ **Perte sécurité périmétrale** (compromission réseau interne)

Pourquoi PRIORITÉ HAUTE : Le pare-feu est le point de passage unique pour tout trafic externe. Une panne pare-feu ne crée pas d'arrêt production immédiat, mais crée une **exposition critique** pendant 30+ secondes. Le risque ransomware qui en découle rend cette infrastructure fondamentale pour la sécurité du PRA.

● Niveau 4 - MOYENNE : VPN IPsec AES-256 + Serveurs CAO/PLM

Éléments couverts : Tunnel VPN chiffré + Serveurs CAO/PLM (Cloud SecNumCloud)

Objectifs de continuité :

- **RPO** : 24h (sauvegarde quotidienne vers BLOC 3)
- **RTO** : 24h (J+1 acceptable)
- **Justification mécanisme** : Redondance intra-datacenter + sauvegarde asynchrone quotidienne

Impact métier en cas de défaillance :

-  **Bureau d'Études en chômage technique** (24h tolérable)
-  **Propriété intellectuelle sécurisée mais inaccessible** (accès retardé)
-  **Pas d'impact production immédiat** (ERP continue localement)
-  **Retard conception/ingénierie** (impact J+2 minimum)

Pourquoi PRIORITÉ MOYENNE : Contrairement à la production, l'arrêt de la BDE peut être toléré 24h sans mettre en péril l'usine. Les concepteurs/ingénieurs peuvent travailler offline temporairement. Mais au-delà de 24h, l'impact devient stratégique. La souveraineté données (SecNumCloud France) et la conformité RGPD justifient cette haute disponibilité, mais avec une tolérance 24h.

● Niveau 5 - SUPPORT : Internet Redondance (Fibre + 4G/Starlink)

Éléments couverts : Lien Fibre principal + liaisons 4G/5G/Satellite de secours + SD-WAN

Objectifs de continuité :

- **RTO** : <5 min (bascule automatique SD-WAN)
- *Note : RPO non applicable — pas de données stockées sur la liaison Internet.*
- **Justification mécanisme** : Redondance multi-fournisseurs + health checks continus

Impact métier en cas de défaillance :

- ⚠ **Dégradation temporaire accès BDE** (<5 min tolérable)
- ⚠ **Pas d'impact production** (ERP fonctionne offline en local)
- ⚠ **Continuité assurée** via basculement automatique 4G/Satellite
- ⚠ **Capacité réduite** sur 4G (mais suffisante pour email/collaboration)

Pourquoi PRIORITÉ SUPPORT : Une coupure fibre sectionnée par travaux BTP arrive plusieurs fois par an. La redondance 4G/Satellite prévient le chômage technique BDE sans coût d'arrêt majeur. C'est une **couche de continuité pratique** plutôt qu'une question de survie.

Synthèse - Matrice de Restauration Prioritaire

Priorité	Éléments	RTO/RPO	Impact si Défaillance	Action Post-Sinistre
 1. ABSOLUE	Production ERP + Sauvegarde Locale	RPO 1h / RTO 4h	Usine paralysée → Pénalités clients, faillite court-terme	Restauration immédiate depuis NAS local
 2. STRATÉGIQUE	Réplication Hors Site + Stockage WORM	RPO 4–24h / RTO 4–24h	Perte totale → Impossibilité récupération = faillite	Restauration depuis coffre-fort distant (>50km)
 3. HAUTE	Cluster Pare-feu redondant	RTO <30 sec	Exposition Internet → Risque ransomware immédiat	Basculement automatique Actif→Passif
 4. MOYENNE	VPN IPsec + Serveurs CAO/PLM	RPO 24h / RTO 24h	Chômage technique BDE (24h tolérable)	Restauration J+1 depuis sauvegarde quotidienne
 5. SUPPORT	Internet Redondance (Fibre+4G)	RTO <5 min	Dégradation temporaire accès BDE	Basculement automatique SD-WAN

Cette hiérarchie de criticité **guide toutes les décisions du PRA** :

- Chapitre 2 (Analyse de risque EBIOS RM)** : Identifier les menaces prioritaires contre ces niveaux 1–2 (ransomware, sinistres physiques, coupures réseau).
- Chapitre 3 (Architecture technique détaillée)** : Configure les redondances et failovers selon priorité (Pare-feu Actif/Passif pour Niveau 3, Sauvegarde immuable pour Niveau 2).
- Chapitre 4 (Stratégie de Reprise & Gestion de Crise)** : Prévoit les procédures de restauration par ordre de priorité (Niveau 1 = 1ère 4h, Niveau 2 = hors-site, etc.).

4. **Chapitre 5 (Conformité RGPD)** : Valide que les mesures techniques (chiffrement, immuabilité) garantissent la protection des données pour chaque niveau.

1.3. Enjeux et Contraintes Critiques

- Continuité Opérationnelle (Juste-à-Temps) : L'industrie aéronautique fonctionne en flux tendu. Tout arrêt de notre production supérieur à quelques heures impacte directement la chaîne d'assemblage finale de nos clients. La disponibilité de l'ERP est donc critique.
- Confidentialité et Conformité (EN9100) : En tant que détenteur de données techniques sensibles, nous devons garantir la confidentialité absolue contre l'espionnage industriel, conformément à la norme EN9100 et aux exigences de cybersécurité de nos partenaires.

2. ANALYSE D'IMPACT SUR L'ACTIVITÉ (BIA) ET OBJECTIFS (SLA)

L'analyse d'impact (BIA) permet d'identifier les conséquences d'une interruption sur nos processus.

2.1. Échelle de Gravité et Contexte

Pour évaluer les risques, nous utilisons l'échelle d'impact suivante, adaptée à une PME de 400 personnes soumise aux contraintes aéronautiques :

- **Niveau 1 (Faible)** : Perturbation mineure, pas d'impact sur la production.
- **Niveau 2 (Modéré)** : Arrêt de production < 4h, retard rattrapable en interne.
- **Niveau 3 (Important)** : Arrêt de production > 1 jour, pénalités financières, perte de confiance client.
- **Niveau 4 (Critique)** : Arrêt > 3 jours, rupture de contrat Airbus, menace pour la survie de l'entreprise.

2.2. Hiérarchie de Criticité Métier (SLA)

L'infrastructure est classée en 5 niveaux de criticité pour guider les priorités de restauration:

- Niveau 1 - ABSOLUE (Production ERP + Sauvegarde Locale) : RPO 1h / RTO 4h.
L'ERP est le cœur opérationnel de l'usine. Tout arrêt >4h paralyse l'usine et entraîne une perte de traçabilité EN9100.
- Niveau 2 - STRATÉGIQUE (Réplication Hors Site + Stockage WORM) : RPO 4-24h / RTO 4-24h. Sans sauvegarde hors site protégée contre les ransomwares, AeroTech ne peut pas se rétablir d'une catastrophe majeure. C'est l'assurance-vie du PRA.
- Niveau 3 - HAUTE (Cluster Pare-feu Redondant) : RTO <30 sec (bascule automatique). Empêche l'exposition sur Internet et le risque de ransomware.
- Niveau 4 - MOYENNE (VPN IPsec + Serveurs CAO/PLM) : RPO 24h / RTO 24h. L'arrêt du Bureau d'Études peut être toléré 24h sans mettre en péril l'usine (chômage technique tolérable).
- Niveau 5 - SUPPORT (Internet Redondance Fibre+4G) : RTO <5 min (bascule SD-WAN). Empêche la dégradation temporelle de l'accès BDE.

(Note Technique : Le Socle IT (IAM/DNS/NTP/PKI) dispose d'un RTO et RPO de 4h, indispensable à l'authentification globale).

3. ANALYSE DE RISQUES (MÉTHODE EBIOS RM)

Cette analyse vise à identifier les menaces pesant sur l'activité d'AeroTech afin de dimensionner le PRA de manière pragmatique.

3.1. Échelle de Gravité et Contexte

Pour évaluer les risques, nous utilisons l'échelle d'impact suivante, adaptée à une PME de 400 personnes soumise aux contraintes aéronautiques :

- **Niveau 1 (Faible)** : Perturbation mineure, pas d'impact sur la production.
- **Niveau 2 (Modéré)** : Arrêt de production < 4h, retard rattrapable en interne.
- **Niveau 3 (Important)** : Arrêt de production > 1 jour, pénalités financières, perte de confiance client.
- **Niveau 4 (Critique)** : Arrêt > 3 jours, rupture de contrat Airbus, menace pour la survie de l'entreprise.

3.2. Cartographie des Actifs (Biens Essentiels & Supports)

Nous avons corrélé les enjeux métiers ("Valeurs Métier") avec les équipements informatiques qui les supportent ("Biens Supports").

Valeur Métier (Enjeu)	Bien Support (Technique)	Impact en cas de perte
VM1 : Production & Logistique	Svr-ERP (On-Premise)	Disponibilité : Si l'ERP s'arrête, l'usine ne peut plus produire et les camions de livraison restent à quai.
VM2 : Propriété Intellectuelle	Cloud CAO & Svr-Fichiers	Confidentialité : Le vol de plans techniques compromet le secret industriel et entraîne la perte des contrats Airbus.
VM3 : Accès aux Données	Liaison Internet & VPN	Disponibilité : Sans lien réseau, le Bureau d'Études ne peut plus accéder au Cloud Privé (Chômage technique).

3.3. Matrice des Risques (Synthèse des Scénarios)

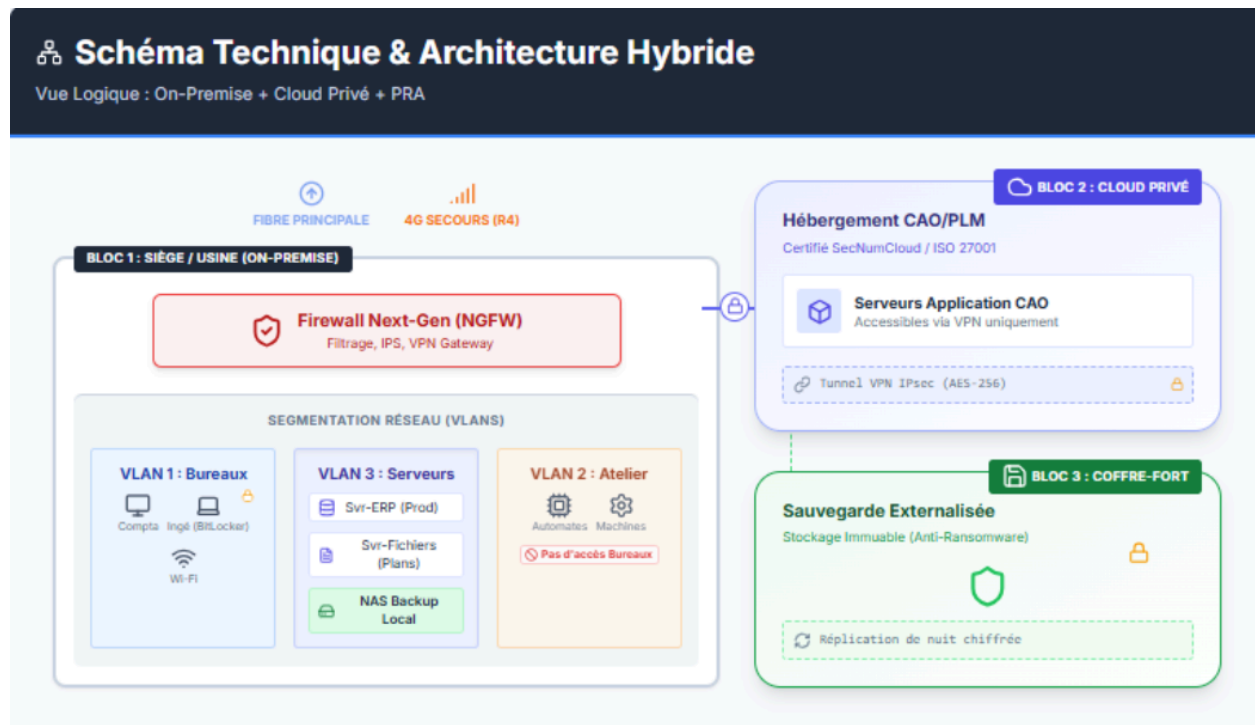
Le tableau ci-dessous synthétise les scénarios redoutés et les mesures de sécurité mises en face (Prévention, Protection, Réaction).

ID	Menace (Scénario)	Type d'Attaquant	Risque Initial (I × P)	Mesures de Traitement (PRA & Sécurité)	Risque Résiduel (I × P)
R1	Ransomware Chiffrement de l'ERP.	Cybercriminels / Hackers externes.	12 (CRITIQUE) (I:4 × P:3)	Segmentation réseau (VLAN). Sauvegardes immuables (WORM).	4 (FAIBLE) (I:4, P:1) L'immuabilité empêche la perte.
R2	Espionnage Industriel Vol de plans CAO.	Concurrents / Employés compromis.	8 (ÉLEVÉ) (I:4 × P:2)	Chiffrement flux VPN, DLP, Authentification MFA.	4 (FAIBLE) (I:4, P:1) L'accès non autorisé est bloqué.
R3	Sinistre Physique Incendie local.	Catastrophe naturelle / Accident.	4 (MOYEN) (I:4 × P:1)	Site de secours distant (>50km). Externalisation Cloud.	1 (TRÈS FAIBLE) (I:1, P:1) Reprise garantie.
R4	Coupure Internet Sectionnement fibre.	Erreur humaine externe / BTP.	9 (ÉLEVÉ) (I:3 × P:3)	Redondance Fibre + 4G/Starlink avec bascule SD-WAN.	3 (FAIBLE) (I:1, P:3) Impact opérationnel annulé.
R5	Erreur Humaine Suppression de projets.	Collaborateur interne.	4 (FAIBLE) (I:2 × P:2)	Versionning des fichiers (Snapshots horaires).	2 (TRÈS FAIBLE) (I:1, P:2) Restauration immédiate.

4. ARCHITECTURE TECHNIQUE & SÉCURITÉ

4.1. Vue Logique Détaillée (Architecture Hybride)

L'infrastructure est segmentée en zones de confiance (OT/IT/DMZ) réparties sur 3 blocs:



BLOC 1 : Le Site de Production (On-Premise)

C'est le cœur de l'usine, hébergeant les ressources critiques nécessitant une latence nulle.

- **Sécurité Périmétrique (Cluster Haute Disponibilité) :** Un **Cluster de Firewalls Next-Gen (NGFW) en mode Actif/Passif** assure le filtrage strict des entrées/sorties. Si l'équipement principal subit une panne matérielle, l'équipement de secours prend le relais instantanément pour garantir que le tunnel VPN et la production ne soient jamais coupés.
- **Segmentation Réseau (VLANs) :**
 - *VLAN Bureaux* : Postes administratifs et ingénieurs.
 - *VLAN Atelier (Prod)* : Automates et terminaux industriels. Ce réseau est isolé pour empêcher la propagation latérale d'un virus depuis les bureaux.
 - *VLAN Serveurs* : Zone hébergeant l'ERP de production et le NAS de sauvegarde locale.

BLOC 2 : Le Cloud Privé (Applications CAO)

Hébergé chez un prestataire certifié, ce bloc contient les serveurs d'application CAO/PLM.

- **Accès :** Exclusivement via un tunnel VPN IPsec (chiffrement AES-256) établi depuis le firewall de l'usine. Aucun accès direct depuis Internet n'est possible.

BLOC 3 : Le "Coffre-fort" (Sauvegarde Externalisée)

Ce site tiers reçoit les répliques de nuit. Il est constitué de stockage immuable (technologie WORM ou équivalent) pour garantir qu'aucune donnée ne puisse être écrasée ou chiffrée par un ransomware pendant la durée de rétention.

Supervision & DMZ : Les échanges externes transitent via une DMZ sécurisée avec portail SFTP chiffré. La surveillance s'opère via Zabbix/Prometheus, un EDR (postes et serveurs), et une journalisation centralisée.

4.2. Gestion des SPOF (Single Point of Failure)

L'architecture a été durcie pour éliminer les défaillances uniques:

- DNS/AD/PKI indisponibles : Parade via redondance (2 DC), sauvegarde de l'état du système et procédures de comptes "break-glass".
- Stockage SAN défaillant : Parade via double contrôleur/RAID, réplication et sauvegardes WORM.
- Firewall/VPN HS : Parade via Haute Disponibilité (HA) NGFW/VPN et sauvegarde de la configuration.
- Comptes admin compromis : Parade via MFA/PAM, segmentation, comptes dédiés au backup et alerting.

4.3. Souveraineté

Le choix des hébergeurs répond à des contraintes légales et physiques strictes :

- **Souveraineté des Données** : Afin de respecter la protection du patrimoine industriel stratégique, l'intégralité des données (Cloud Privé et Sauvegardes) est hébergée sur le territoire français (ou UE strict) chez un prestataire certifié **SecNumCloud**.
- **Distance Géographique** : Le site de secours ("Coffre-fort") est situé à plus de **50 km** du site de production principal. Cette distance garantit que les deux sites ne seront pas impactés simultanément par le même sinistre majeur (crue régionale, séisme, coupure électrique étendue)

5. STRATÉGIE DE REPRISE ET GESTION DE CRISE

5.1. Stratégie de Sauvegarde Technique (3-2-1-1-0)

Nous appliquons la règle d'or pour garantir la restauration:

- 3 copies de la donnée (Production + Backup Local + Backup Externalisé)
- 2 supports différents (Disque NAS + Cloud/Bande).
- 1 copie hors site (Géographiquement distante de >50km).
- 1 copie immuable (Hors-ligne ou verrouillée WORM) pour contrer les ransomwares.
- 0 erreur (Sauvegardes testées et vérifiées).

5.2. Procédure de Gestion de Crise (Phase Initiale)

- 1. Alerte & Confinement (0-30 min) : Isoler les segments impactés, bloquer les comptes suspects, et débrancher physiquement le câble réseau "Uplink" pour couper la propagation.
- 2. Analyse & Décision (30 min - 1h) : Réunion de la Cellule de Crise, qualification de l'incident, activation du PRA, information au donneur d'ordre (Airbus) et à l'assureur.

5.3. RUNBOOK TECHNIQUE (Ordre strict de Reprise)

Pour la phase de restauration (H+1 à H+4), les équipes techniques suivent cette séquence ordonnée afin d'éviter les conflits de dépendance:

- 1) Socle : Restauration IAM / DNS / NTP / PKI.
- 2) Réseau : Rétablissement WAN / SD-WAN + VPN IPsec + règles Firewall minimales.
- 3) Stockage : Vérification du SAN.
- 4) Hyperviseur : Relance de la virtualisation et du cluster.
- 5) Base de données : Restauration de la base ERP.
- 6) Applicatif : Lancement de l'applicatif ERP.
- 7) Fichiers : Reconnexion des partages plans.
- 8) Tests : Réalisation des tests fonctionnels.
- 9) Réouverture : Réouverture progressive de l'IT puis de l'OT.

5.4. Annuaire de Crise (Matrice RACI)

Répartition des responsabilités (Réalisateur, Approbateur, Consulté, Informé):

- Directeur de Crise (Direction Générale) : Validation de l'activation du PRA (Approbateur) et Communication Presse.
- Responsable Technique (DSI / Responsable IT) : Pilotage technique de la restauration (Approbateur/Réalisateur).
- RSSI / Sécurité : En charge du confinement (Réalisateur).
- Support Hébergeur & ERP : Accès aux sauvegardes et assistance au redémarrage des bases de données (Consultés).
- Métiers : Validation de la reprise (Réalisateur/Approbateur).

5.5. Tests et MCO (Maintenance en Condition Opérationnelle)

- Mensuel : Test automatisé de restauration de fichiers plans.
- Trimestriel : Test sur VM non critique.
- Semestriel : Exercice sur table (Table top).
- Annuel : Crash Test ERP (Bascule réelle) avec mesure effective du RTO/RPO.
- *Déclencheur spécifique* : Tests supplémentaires après tout changement majeur (VPN, hyperviseur, stockage, IAM).

6. CONFORMITÉ RGPD & CADRE LÉGAL

6.1. Gouvernance et Mesures Techniques

- Gouvernance : La Direction Générale est le Responsable de Traitement, appuyée par un DPO assurant le lien avec la CNIL.
- Chiffrement (Privacy by Default) : Les données sensibles stockées sur les ordinateurs portables sont chiffrées via BitLocker.
- Gestion des Droits (Privacy by Design) : Application stricte du "moindre privilège" (ex: un ingénieur CAO n'a aucun accès aux dossiers RH).

6.2. Cartographie des Données (Registre des Traitements)

Les données à caractère personnel sont conservées selon les durées suivantes:

- Gestion RH & Paie : Noms, salaires, NIR. Conservation : 5 ans après le départ du salarié.
- Sécurité & Accès : Logs de connexion (6 mois selon l'ANSSI) et Vidéosurveillance (30 jours max).
- Relations Tiers : Noms des contacts Airbus/Fournisseurs. Conservation : 3 ans après la fin de la relation commerciale.

6.3. Sous-traitance et Souveraineté

Nos prestataires externes (Cloud, Sauvegarde) agissent en tant que sous-traitants. Leurs contrats incluent les clauses types de protection des données. Toutes les données sont hébergées dans l'Union Européenne (France privilégiée), garantissant la souveraineté numérique et interdisant tout transfert hors UE.